

03 계정 찾기·비밀번호 재설정

이메일 인증 코드 기반 계정 복구

구분	내용
문서 목적	인증번호 발급·확인·1회 사용과 계정 복구의 전체 흐름을 추적한다.
관련 파일	member/controller/RecoveryController.java member/service/EmailVerificationService.java member/service/VerificationMailService.java member/service/MemberService.java member/entity/EmailVerification.java templates/member/find-id.html templates/member/password-reset.html
기준	2026-07-29 현재 워크스페이스
기술	Spring Boot 3.5.16 / Java 21 / Thymeleaf / Spring Security / JPA

읽는 순서

요청 흐름 → 파일 책임 → 핵심 코드 → 검증·주의사항 순으로 구성했다.

01 아이디 찾기

이름과 이메일을 확인한 뒤 마스킹 ID 표시

메일 요청

- RecoveryController가 이름·이메일과 일치하는 ACTIVE 회원이 있는지 먼저 확인한다.
- 존재하면 FIND_ID 목적의 인증 코드를 발송하고 세션에 이름·정규화 이메일을 저장한다.
- 계정 존재 여부 노출을 줄이기 위해 성공·실패와 관계없이 같은 안내 문구를 반환한다.

코드 확인

- 세션의 이름·이메일이 없으면 먼저 인증번호를 요청하도록 안내한다.
- confirmAndConsume이 코드를 검증하고 즉시 사용 처리한다.
- MemberService.findMaskedLoginId가 아이디 일부만 보여준다.

흐름

입력 → 회원 일치 검사 → 이메일 발송 → 코드 확인 → 코드 소비 → 마스킹 아이디 표시

02 비밀번호 재설정

아이디와 이메일을 확인한 뒤 새 해시 저장

메일 요청

- loginId + email + ACTIVE 상태가 일치하는지 검사한다.
- PASSWORD_RESET 목적 코드를 보내고 세션에 loginId와 email을 저장한다.

변경 확정

- 새 비밀번호와 확인값, 복잡도 규칙을 확인한다.
- 인증 코드를 확인하고 1회 사용 처리한다.
- MemberService.resetPassword가 다시 회원을 찾고 BCrypt 해시를 저장한다.

목적 분리

VerificationPurpose	사용처
FIND_ID	아이디 찾기
PASSWORD_RESET	비밀번호 재설정

주의

코드 소비와 비밀번호 변경이 서로 다른 서비스 트랜잭션이다. DB 저장 실패까지 고려하면 두 작업을 하나의 유스케이스 트랜잭션으로 묶는 편이 안전하다.

03 인증 코드 수명주기

EmailVerificationService의 규칙

규칙	현재 값	의미
재요청 제한	1분	짧은 시간 내 반복 발송 방지
유효 시간	5분	만료된 코드 거절
최대 시도	5회	무차별 대입 제한
저장 방식	PasswordEncoder 해시	DB에 원문 코드 저장 안 함
사용 횟수	1회	usedAt 설정 후 재사용 차단

메일 발송 모드

- compick.mail.mode=log이면 실제 발송 대신 애플리케이션 로그에 코드를 남긴다.
- smtp이면 JavaMailSender로 HTML 인증 메일을 발송한다.
- SMTP 계정은 환경변수 SMTP_USERNAME, SMTP_PASSWORD를 사용한다.

운영 설정

운영에서는 log 모드를 비활성화하고 인증 코드가 로그에 평문으로 남지 않도록 해야 한다.